

CargoBit

Sicherheitsarchitektur

Rollen, Berechtigungen & Anti-Fraud System

Enterprise Security Documentation v1.0

Dokument-Typ	Technische Architektur
System	CargoBit Logistik-Plattform
Geltungsbereich	Europaweit (EU + UK + CH)
Klassifikation	Intern – Vertraulich

Inhaltsverzeichnis

1. Rollenuebersicht und Grundprinzipien	
.....	3
2. Berechtigungslogik pro Rolle	4
3. KYC/KYB Verifikations-Workflows	
8	
4. Anti-Fraud System Architecture	
10	
5. Risk Scoring Algorithmus	12
6. Technische Sicherheitsmassnahmen	
. 14	
7. Audit-Logging & Compliance	16

1. Rollenuebersicht und Grundprinzipien

1.1 Systemrollen

CargoBit implementiert ein rollenbasiertes Zugriffskontrollsystem (RBAC), das sieben definierte Rollen umfasst. Jede Rolle wurde spezifisch fuer die Anforderungen einer europaeischen Logistikplattform entwickelt und folgt dem Prinzip der geringsten Privilegien (Least Privilege). Die Rollendefinition beruecksichtigt sowohl operative Notwendigkeiten als auch regulatorische Anforderungen aus GDPR, AML-Richtlinien und Verkehrsrecht.

Rolle	Beschreibung	Zugriffsebene
ADMIN	Systemadministration, volle Kontrolle	Vollzugriff
SUPPORT	Kundensupport, Ticket-Bearbeitung	Lesend + Tickets
SHIPPER_COMPANY	Versender mit Unternehmenskonto	Eigene Transporte
SHIPPER_PRIVATE	Privatversender	Eigene Transporte
DISPATCHER	Disponent, Flottenverwaltung	Firmen-Flotte
DRIVER_SELF_EMPLOYED	Selbststaendiger Fahrer	Eigene Auftraege
MARKETER	Marketing-Kampagnen	Kampagnen-Verwaltung

Tabelle 1.1: Systemrollen-Uebersicht

1.2 Sicherheitsgrundsaeetze

Die Berechtigungsarchitektur basiert auf vier fundamentalen Sicherheitsprinzipien, die in allen Systembereichen konsequent angewendet werden. Diese Grundsaeetze bilden die Basis fuer alle Zugriffskontrollentscheidungen und stellen sicher, dass Benutzer nur diejenigen Funktionen und Daten sehen koennen, die fuer ihre Arbeit erforderlich sind. Die konsequente Umsetzung dieser Prinzipien schuetzt sowohl vor internen Missbrauch als auch vor externen Angriffen.

Prinzip	Beschreibung	Implementierung
Least Privilege	Minimale noetige Rechte	Rollen-spezifische Berechtigungen

Funktionstrennung	Geld vs. Pruefung getrennt	Support darf keine Finanzen
Mandantentrennung	Firmen-Daten isoliert	Company-Scoped Queries
Audit-Trail	Alle Aktionen protokolliert	audit_logs Tabelle

Tabelle 1.2: Sicherheitsgrundsätze

2. Berechtigungslogik pro Rolle

2.1 ADMIN - Systemadministrator

Die ADMIN-Rolle gewaehrt den umfassendsten Zugriff auf das System. Administratoren koennen Benutzerkonten verwalten, Rollen zuweisen, Systemeinstellungen konfigurieren und Verifikationen final freigeben. Um die Integritaet des Systems zu gewaehrleisten, duerfen Administratoren keine operativen Transporte erstellen oder manipulieren. Diese Einschraenkung verhindert Interessenkonflikte und stellt sicher, dass operative und administrative Funktionen strikt getrennt bleiben.

Aktion	Erlaubt	Einschraenkung
Rollen zuweisen	Ja	Audit-Pflichtig
Plaene verwalten	Ja	–
System-Settings	Ja	Audit-Pflichtig
Logs einsehen	Ja	–
Verifikationen freigeben	Ja	Nur mit Begründung
Transporte erstellen	Nein	Ausnahme mit Audit
Wallet-Transaktionen	Nur einsehen	Keine Ausloesung

Tabelle 2.1: ADMIN-Berechtigungen

2.2 SUPPORT - Kundensupport

Support-Mitarbeiter haben Zugriff auf Tickets und koennen Transportdaten lesen, um Kunden bei Anfragen zu unterstuetzen. Sie koennen Benutzer voruebergehend sperren und entsperren, duerfen jedoch keine finanziellen Transaktionen ausloesen oder Plaene aendern. Diese Einschraenkung ist kritisch fuer die Funktionstrennung, da Support-Mitarbeiter niemals die Moeglichkeit haben duerfen, Geldbewegungen zu initiieren oder kontrollieren.

Aktion	Erlaubt	Notiz
Tickets bearbeiten	Ja	Volle CRUD
Transportdaten lesen	Ja	Alle Transporte
Benutzer sperren	Ja	Mit Dokumentation
Wallet-Transaktionen	Nein	Komplett gesperrt

IBAN aendern	Nein	–
Plaene buchen	Nein	–
Angebote abgeben	Nein	–

Tabelle 2.2: SUPPORT-Berechtigungen

2.3 SHIPPER - Versender

Versender (privat oder als Unternehmen) koennen Transporte anlegen, bearbeiten und stornieren, solange der Transport noch nicht einem Fahrer zugewiesen wurde. Nach der Zuweisung sind Aenderungen nur noch in Absprache mit dem zugeordneten Fahrer moeglich. Versender haben Zugriff auf ihre eigenen Dokumente und Rechnungen, koennen ihre Wallet fuer Einzahlungen und Zahlungen nutzen, haben jedoch keinen Einblick in Fahrerdaten anderer Transporte oder in die Matching-Algorithmen.

2.4 DISPATCHER - Disponent

Dispatcher arbeiten auf der Carrier-Seite und verwalten die Fahrzeuge und Fahrer ihrer Firma. Sie koennen Auftraege sehen, die zum Firmenprofil passen, Angebote abgeben und Fahrer sowie Fahrzeuge zuweisen. In Buero-Workflows koennen Dispatcher Status im Namen des Fahrers setzen. Der Zugriff auf Wallets und Finanzen anderer Firmen ist strikt unterbunden, genau wie der Einblick in Shipper-Daten ausserhalb der direkt zugeordneten Auftraege.

2.5 DRIVER - Fahrer

Fahrer sehen ihre zugewiesenen Auftraege und koennen den Status aktualisieren (Abholung, Lieferung, Fotos, Unterschriften). Sie verwalten ihre eigenen Dokumente wie Fuehrerschein und ADR-Bescheinigung. Fahrer koennen keine Preise aendern oder Angebote abgeben, es sei denn, dies wurde explizit durch die Firmenkonfiguration erlaubt. Der Zugriff auf Firmen-Wallets und Auszahlungen ist gesperrt.

3. KYC/KYB Verifikations-Workflows

3.1 KYC - Know Your Customer (Personen)

Die KYC-Verifizierung ist obligatorisch fuer alle Benutzerrollen mit finanziellen oder operativen Funktionen. Ohne abgeschlossene KYC-Verifizierung bleiben die Benutzerkonten in einem eingeschaenkten Status, der keine hohen Betraege, keine Gefahrguttransporte und keine internationalen Transporte zulaesst. Die Verifizierung erfolgt in drei Stufen und beinhaltet die Pruefung von Ausweisdokumenten, Selfie-Match und ggf. Fuehrerschein sowie ADR-Nachweise.

Stufe	Dokument	Pruefung	Freigabe
1	Ausweis (Personalausweis/Pass)	OCR + Echtheitspruefung	Automatisch + Manuell
2	Selfie-Match	Face Recognition	Automatisch
3	Fuehrerschein (optional)	Klasse + Gueltigkeit	Manuell
4	ADR-Nachweis (optional)	Klassen + Gueltigkeit	Manuell

Tabelle 3.1: KYC-Verifizierungsstufen

3.2 KYB - Know Your Business (Unternehmen)

Die KYB-Verifizierung ist zwingend fuer Speditionen, Firmen-Versender und Marketer mit Rechnungsstellung. Ohne KYB-Abschluss gelten limitierte Auftragssummen, keine Vorauszahlungen und keine Massen-Kampagnen. Die Unternehmensverifizierung prueft die rechtliche Existenz, die wirtschaftlich Berechtigten und die steuerliche Registrierung. Fuer Unternehmen aus dem Nicht-EU-Ausland gelten zusaetzliche Anforderungen.

Dokument	EU-Unternehmen	Nicht-EU
Handelsregistrauszug	Pflicht	Pflicht + Uebersetzung
USt-IdNr. Nachweis	Pflicht	Optional
Gesellschafterliste	Pflicht	Pflicht
Wirtschaftlich Berechtigte	UBO-Erklaerung	UBO + KYC aller UBOs
Zertifizierter Uebersetzer	–	Alle Dokumente

Tabelle 3.2: KYB-Anforderungen nach Region

4. Anti-Fraud System Architecture

4.1 Fraud-Detection-Ebenen

Das Anti-Fraud-System von CargoBit arbeitet auf drei Ebenen: Account-Ebene, Transaktions-Ebene und Transport-Ebene. Jede Ebene nutzt spezifische Erkennungsmechanismen und generiert bei Ueberschreitung von Schwellenwerten Security-Flags. Das System kombiniert automatische Analysen mit regelbasierten Pruefungen und kann bei kritischen Faellen automatisch einschreiten.

Ebene	Pruefung	Aktion bei Flag
Account	Login-Patterns, IP-Wechsel, Geraete-Aenderung	2FA, Captcha, Temporaere Sperrung
Transaktion	Hohe Betraege, Neue IBAN, Many Stornos	Delay, Manuelle Freigabe, Limit
Transport	GPS-Plausibilitaet, Fake-Dokumente	Verifikations-Workflow, Sperre

Tabelle 4.1: Fraud-Detection-Ebenen

4.2 Account-Ebene: Erkennungsmechanismen

Auf Account-Ebene ueberwacht das System ungewoehnliche Login-Muster einschliesslich IP-Adressen und Laenderwechsel. Bei vielen fehlgeschlagenen Logins werden Rate-Limiting und Captcha aktiviert. Neue Geraete erfordern eine Bestaetigung per E-Mail oder 2FA. Diese Mechanismen schuetzen vor Account-Uebernahmen und Credential-Stuffing-Angriffen.

Flag-Typ	Trigger	Severity
UNUSUAL_LOGIN_LOCATION	Login aus neuem Land	MEDIUM
MULTIPLE_FAILED_LOGINS	>5 fehlgeschlagene Versuche	LOW
NEW_DEVICE_DETECTED	Neues Geraet erkannt	LOW
SIMULTANEOUS_SESSIONS	Gleichzeitige Sessions	HIGH
IMPOSSIBLE_TRAVEL	Login von weit entfernten Orten	CRITICAL

Tabelle 4.2: Account-Level Security Flags

4.3 Transaktions-Ebene

Transaktionen werden auf Anomalien geprueft. Hohe Betraege loesen zusaetzliche Checks aus, entweder als manuelle Freigabe durch SUPPORT oder als zeitliche

Verzoegerung. Die Kombination aus neuer IBAN und hohem Payout generiert automatischein Flag mit vorgeschalteter Verzoegerung. Eine hohe Stornierungsrate oder vieleSchadensmeldungen fuehren zu einem erhoekten Risk-Score fuer den betroffenenAccount.

4.4 Transport-Ebene

Auf Transport-Ebene wird die GPS-Plausibilitaet geprueft: Befindet sich der Fahrer tatsaechlich in der Naehe des angegebenen Standorts? Wiederkehrende Muster wie immer gleiche Shipper-Carrier-Kombinationen mit auffaelligen Zahlungen werden analysiert. Verdacht auf gefaelschte Dokumente loest einen Verifikations-Workflow aus, bei dem die Dokumente manuell geprueft werden muessen.

5. Risk Scoring Algorithmus

5.1 Risk-Score-Berechnung

Jeder Benutzer und jedes Unternehmen erhaelt einen Risk-Score zwischen 0 und 100, wobei 0 das geringste Risiko und 100 das hoechste Risiko darstellt. Der Score setzt sich aus gewichteten Einzelkomponenten zusammen und wird bei jeder relevanten Aktion neu berechnet. Ueberschreitet der Score kritische Schwellen, werden automatisch Einschraenkungen aktiviert oder manuelle Pruefungen angefordert.

Komponente	Gewicht	Faktoren
KYC/KYB Status	25%	Verified/Pending/Rejected
Security Flags	20%	Anzahl + Severity
Transaktions-Historie	20%	Stornos, Schaeden, Betraege
Account-Alter	15%	Tage seit Registrierung
Verhaltens-Anomalien	10%	Patterns, GPS, Logins
Externe Scores	10%	Credit-Bureaus (optional)

Tabelle 5.1: Risk-Score Komponenten

5.2 Score-Schwellen und Aktionen

Score-Bereich	Risiko-Level	Automatische Aktion
0-25	LOW	Keine Einschraenkungen
26-50	MEDIUM	Transaktions-Limits
51-75	HIGH	Manuelle Freigabe bei Payouts
76-100	CRITICAL	Account gesperrt, Review noetig

Tabelle 5.2: Risk-Score Schwellenwerte

6. Technische Sicherheitsmassnahmen

6.1 Authentifizierung

CargoBit verwendet JWT (JSON Web Tokens) mit kurzer Gueltigkeitsdauer in Kombination mit Refresh-Tokens. Fuer kritische Rollen wie ADMIN und DISPATCHER grosser Flotten ist 2FA (Zwei-Faktor-Authentifizierung) zwingend erforderlich. Die Token-Verwaltung beinhaltet automatische Rotation und Revocation bei Sicherheitsereignissen.

Massnahme	Implementierung	Rollen
JWT Access Token	15 Minuten Gueltigkeit	Alle
Refresh Token	7 Tage, Rotation bei Nutzung	Alle
2FA (TOTP)	Google Authenticator kompatibel	ADMIN, DISPATCHER
2FA (SMS)	Fallback-Option	Optional alle
Session-Timeout	30 Minuten Inaktivitaet	Alle

Tabelle 6.1: Authentifizierungsmassnahmen

6.2 Transport-Verschlüsselung

Saemtliche Kommunikation erfolgt verschluesselt ueber TLS 1.3. HSTS (HTTP Strict Transport Security) ist aktiviert, und es gibt keine unverschlusselten Endpunkte. Die SSL/TLS-Zertifikate werden automatisch erneuert und auf Schwachstellen ueberwacht.

6.3 Daten-Verschlüsselung

Passwoerter werden mit Argon2id gehasht, einem modernen und resistenten Algorithmus gegen Brute-Force- und Rainbow-Table-Angriffe. Sensible Daten wie IBAN, Ausweisdaten und Kreditkarteninformationen werden zusaetzlich in der Datenbank verschluesselt (AES-256). Die Schluesselverwaltung erfolgt ueber einen separaten Key-Management-Service.

Datentyp	Verschlüsselung	Key-Management
Passwoerter	Argon2id (Hash)	Salt per User
IBAN	AES-256-GCM	KMS Rotation
Ausweisdaten	AES-256-GCM	KMS Rotation

Dokumente (S3)	Server-Side Encryption	AWS KMS
Backups	AES-256	Separate Keys

Tabelle 6.2: Datenverschlüsselung

7. Audit-Logging & Compliance

7.1 Audit-Log Struktur

Jede kritische Aktion wird in der `audit_logs` Tabelle protokolliert. Dies umfasst Rollenaenderungen, Payouts, Planwechsel, Dokumentfreigaben und alle administrativen Eingriffe. Die Logs enthalten Zeitstempel, Akteur, Aktionstyp, Entitaet sowie die Daten vor und nach der Aenderung (JSON). Audit-Logs sind unveraenderbar und werden fuer 7 Jahre aufbewahrt.

Aktionstyp	Beschreibung	Retention
LOGIN	Benutzer-Login	2 Jahre
LOGOUT	Benutzer-Logout	2 Jahre
CREATE	Entitaet erstellt	7 Jahre
UPDATE	Entitaet geaendert	7 Jahre
DELETE	Entitaet geloescht	7 Jahre
STATUS_CHANGE	Status geaendert	7 Jahre
PAYOUT	Auszahlung getaetigt	10 Jahre
FRAUD_ALERT	Fraud-Flag gesetzt	10 Jahre

Tabelle 7.1: Audit-Log Aktionstypen

7.2 Compliance-Anforderungen

CargoBit erfuehlt die Anforderungen der DSGVO (GDPR), der Anti-Geldwaesche-Richtlinie (AML) und der relevanten Verkehrs- und Frachtrechtsgesetze der EU. Datenschutzanfragen (DSGVO Art. 15, 17, 20) werden automatisiert verarbeitet. Fuer Finanztransaktionen gelten die Aufbewahrungsfristen der GoBD und HGB.

Dieses Dokument beschreibt die Sicherheitsarchitektur von CargoBit Stand April 2026. Aktualisierungen erfolgen bei wesentlichen Aenderungen an der Systemarchitektur oder bei neuen regulatorischen Anforderungen.